GridLink Utilities

Operational Technology Gap Assessment

25.01.2025

Azeez Olawale-Arish Yusuff
Edmonton, AB

Executive Summary

This report represents findings from an Operational Technology Gap Assessment of GridLink Utilities' OT environment. This assessment took place over the last 3 months. The goals of this assessment include:

- Performing a current state assessment of GridLink Utilities' OT environment and existing security measures.
- Identification of security gaps in GridLink Utilities' environment
- Risk ratings for all gaps identified in this assessment
- Mapping GridLink Utilities' OT network to the Purdue Model.
- Providing recommendations to address identified gaps and to improve GridLink Utilities' OT security posture
- Prioritizing gaps discovered
- Recommending an implementation roadmap that includes estimated duration and resources required to address the gaps identified

A workshop was held with a number of key stakeholders from the following departments at GridLink Utilities in December 2024: OT operations; OT network; Security Operations Centre and Threat and Vulnerability Management. Through this workshop, and additional research, the following gaps were identified in the OT environment etc.

Critical Risk	High Risk	Medium Risk	Low Risk
	3	1	

The following is a high level summary of the gaps that were identified:

- A **high risk** gap related to not having a dedicated incident response plan for the Operational Technology environment
- A **high risk** gap related to insufficient network segmentation within the OT environment
- A **high risk** gap related not having multi-factor authentication enabled for the virtual desktop environment used to manage OT assets
- A **medium risk** gap related to not hardening routers and switches in the OT environment

Identified gaps have been risk rated and prioritized based on the likelihood and impact of the gaps being exploited and a suggested implementation roadmap has been included.

Current State Analysis

System Overview

GridLink Utilities, a medium-sized utility that operates transmission and distribution of electricity, has been in business for 75 years and currently operates a primary control center and a backup control center for their OT network that are approximately 30 minutes apart. The control centres monitor and control the flow of electricity through the power grid and manage load balancing. GridLink operates 10 transformer stations and 50 distribution stations that cover two medium sized cities and the surrounding areas.

GridLink operates an Operational Technology (OT) network that is used to manage the physical processes of the power utility. The company also operates a corporate or IT network, that is separated from the OT network by firewalls, where enterprise systems are hosted that provide functions such as customer service, billing and regulatory compliance, and an industrial DMZ which is used to securely move data between the corporate and OT networks.

The company operates 250 Windows servers and 75 Linux servers between the primary and the backup control center. These servers run various applications that are used to support the operations of GridLink Utilities' power grid. A wide-area network connects GridLink's control centres to their transformer and distribution stations. And each station that GridLink operates has 1 or 2 workstations that are used to manage the OT devices located at each of the stations.

The main applications that reside in the GridLink Utilities' control centres are the distribution management system (DMS), the energy management system (EMS) and an outage management system (OMS). The DMS is a software platform designed to improve the efficiency, reliability and safety of the electrical distribution grid, which is part of the electrical power system that distributes power from transmission systems to individual customers. While the EMS is a software platform that monitors, controls and optimizes the performance of the power transmission system, the outage management system (OMS) provides outage notifications to their customers through automated phone calls, SMS messages and a mobile application

Existing Security Measures

GridLink Utilities has taken some steps to separate their corporate/IT network from their Operational Technology (OT) environment. It separated its corporate network from their OT network using an industrial demilitarized zone (DMS); a next generation firewalls, with intrusion prevention/detection capabilities to separate their OT and IT networks, used to restrict traffic between the OT network and the corporate network.

While it deployed intrusion detection sensors (IDS) in key areas of their OT network to monitor traffic, it, equally, deployed firewalls at all their stations and are currently halfway finished replacing legacy firewalls at the stations with next generation firewalls that will offer enhanced capabilities such as built in intrusion detection capabilities.

Additionally, firewalls are deployed to restrict traffic leaving GridLink's control centres destined for transformer and distribution stations. Since the Windows and Linux servers located in the control centres, it, equally, deployed anti-virus software on their OT workstations in the control centres and the stations as well.

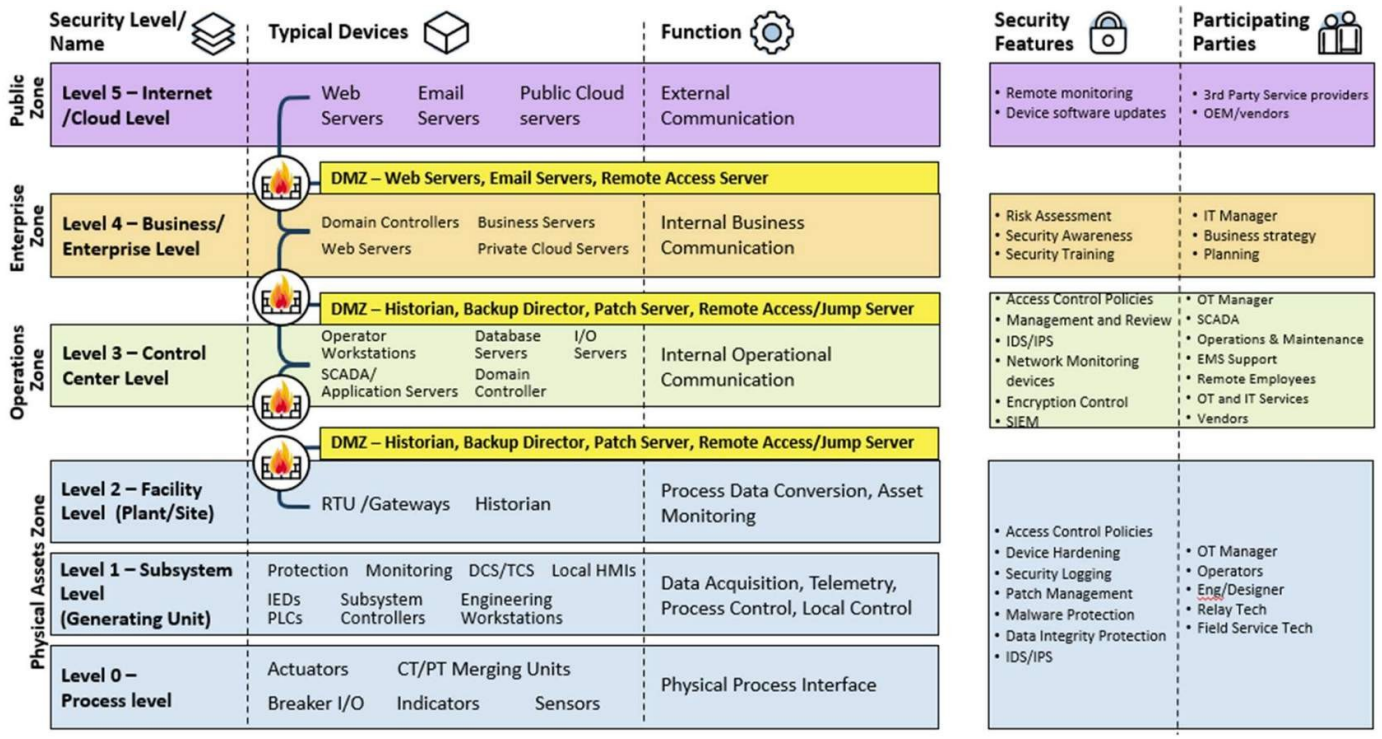
The company's internet access in the OT network is limited to systems or services that need to pull update files, such as security patches or updated virus definition files, from specific vendors. While external facing proxy servers are used to control which systems can communicate to specific websites, internet access is not permitted from GridLink's transformer and distribution stations. Correspondingly, it uses access control lists (ACLs) on routers at their stations to control network traffic in and out of station networks.

For remote access, GridLink has pairs of Internet facing virtual private network (VPN) appliances that allow employees or vendor partners to connect remotely to the OT network and a jump box/server infrastructure which allows users from their corporate network to manage systems that reside in the OT network.

Furthermore, security patches are applied to servers and workstations located at the control center and in stations on a monthly basis, using an automated patch deployment platform. Application related patches are applied to systems such as the distribution management system (DMS) and the energy management system (EMS) on a quarterly basis.

Notably, an agent based automated vulnerability scanning platform is deployed to scan the end user workstations, the Linux and Windows servers in the control center on a weekly basis. Equally, network based scanners are deployed at strategic points on GridLink's OT network and scans of the routers and switches and other network based devices that support the OT network take place on a monthly basis.

Mapping of GridLink's Network to the Purdue Model



Gap Analysis

H-01: No Operational Technology Specific Incident Response Plan

High	**No Operational Technology/Industrial Control System Specific Incident Response Plan**
Description	Although GridLink Utilities does have an incident response program, they do not have an Operational Technology (OT)/Industrial Control System (ICS) specific incident response plan.
Impact	**High**: As OT environments are very different from IT environments, organizations should have OT specific incident response plans to account for the complexities and operational necessities of responding in operational environments. Without

	a dedicated incident response plan for OT, GridLink Utilities may not be prepared to handle security incidents in this environment. Additionally, technology decisions in OT may not align with the necessities of incident response if a dedicated plan does not exist.
Probability	**High**: Security incidents happen fairly regularly in both IT and OT incidents. Attacks against OT environments have become more common. In recent years high profile security incidents have occurred such as the ransomware attack against Colonial Pipeline and the 2015 and 2016 attacks against Ukraine's power grid.
Recommendations	A dedicated OT incident response program should be established. The plan should prioritize actions based on the potential for operational impact and how to position the system to operate through an attack so that it reduces the effect of the attack and the impact on the process under control.
NIST 800-82r3 Reference	Section 3.3.8 Develop an Incident Response Capability

H-02: Insufficient Network Segmentation

High	**Insufficient Network Segmentation**
Description	GridLink has started to segment their OT network and currently have created a secure firewalled zone for their recently upgraded energy management system (EMS). Additionally they have separated their development environment from their production network through recently upgraded next generation firewalls. Although the existing distribution management system (DMS) and the Outage Management System (OMS) both reside in the production zone, they have not been segmented from other OT applications. Plans to segment the DMS system as part of an upgrade should be given high priority.
Impact	**High**: Insufficient network segmentation presents risk in OT environments as it can expose vulnerable systems that were not designed with modern cybersecurity threats in mind. Inadequate segmentation could allow malware or ransomware to spread to other systems or could allow an attacker to move

	laterally across GridLink Utilities' OT network.
Probability	**Medium**: Although some controls are in place to segment OT from IT and the OT, development environment from production, and GridLink stations from their control centres, they should also create additional segmentation zones to further segment systems.
Recommendations	A dedicated OT incident response program should be established. The plan should prioritize actions based on the potential for operational impact and how to position the system to operate through an attack so that it reduces the effect of the attack and the impact on the process under control.
NIST 800-82r3 Reference	Section 6.2.1.3 Network Segmentation and Isolation

H-03: Single Factor Authentication

High	**Single Factor Authentication**
Description	GridLink has implemented multi-factor authentication (MFA) for a large terminal services farm in place in the OT environment that users located outside of GridLink's control centres must use as a "jump server" to manage systems in the control centres or in the downstream transformer and distribution stations but has not implemented MFA for access to their Internet facing OT VPN appliances.
Impact	**High**: The impact of a disgruntled employee or an attacker gaining access to the OT environment through the Internet facing OT VPN appliances could be high. An attacker could potentially gain unauthorized access to critical OT systems and cause outages or put human lives at risk.
Probability	**Medium**: When attackers try to gain access to an OT environment, they frequently target an organization's IT environment first as users typically have access to email and to the Internet. Attackers frequently use phishing emails to try to get end users to install software or provide their user credentials. There is a reasonable chance that if an attacker gained access to GrindLink's IT network, they'd try to access the OT network.

Recommendations	Multi-factor authentication should be enabled on GrindLink's Internet facing OT VPN appliances that are used to access the OT environment from the IT environment. MFA can be safely applied to most OT/ICS environments. As pointed out in the SANS 5 Critical Controls article, MFA has been shown to significantly reduce the number of adversary attack paths. Even though MFA has been applied to the large terminal services farm in place in the OT environment, it should also be applied to the Internet facing OT VPN appliances as a measure to better restrict access to and to protect OT environment.
NIST 800-82r3 Reference	Section 6.2.1.4.4 Multi-Factor Authentication

M-01: Lack of Security Hardening of Servers and Other Devices

Medium	**Lack of Security Hardening of Servers and Other Devices**
Description	During the workshop, it was revealed that GridLink's Threat and Vulnerability Management team runs scans of the servers and workstations in the control center on a weekly basis and provides reports to the OT Operations team and, in return, the OT Operations team patches workstations and servers in the control center on a monthly basis. And after patches are applied, Threat and Vulnerability Management team finally runs a scan to validate the success of the patches that have been deployed. Correspondingly, the teams generally follow industry guidance such as the Center for Internet Security's (CIS) Benchmarks to harden servers and other devices. However, a few exceptions that were noted were as follows A. Systems that are used in GridLink's transformer and distribution stations that are used for local control are not hardened as access to the stations is limited by firewalls at each station and Internet access is not available. B. As a number of legacy operating systems/Windows 2012 servers are still in use, and the Distribution Management System (DMS) is due for an update the coming year, these systems have a number of vulnerabilities that cannot be patched as they are no longer supported by Microsoft.

Impact	**High**: The impact from not hardening servers and other devices in the OT environment could be high. Network devices such as servers and others serve as the backbone of GridLink's communication infrastructure. If these types of devices are not securely configured or are left in their default configuration, they can become prime targets for attackers. This could result in data breaches, network disruptions or compliance violations.
Probability	**Low**: As the servers and other devices are scanned for vulnerabilities regularly and the network team applies patches to address vulnerabilities on a regular basis the probability of this finding being compromised is relatively low.
Recommendations	GridLink's network team should look to adopt the Center for Internet Security's Benchmarks or other hardening guidelines from organizations such as NIST to assist with hardening network switches and routers. If there are no benchmarks available, the network team should ask the manufacturers of the switches and routers they are using for hardening recommendations.
NIST 800-82r3 Reference	Section 5.2.4 - Hardware Security

The risks outlined in this report have been assessed using the GridLink Risk Rating Matrix.

Probability Levels:

1. **Low**: Unlikely to occur.
2. **Medium**: Could occur occasionally.
3. **High**: Very likely or frequently occurring.

Impact Levels:

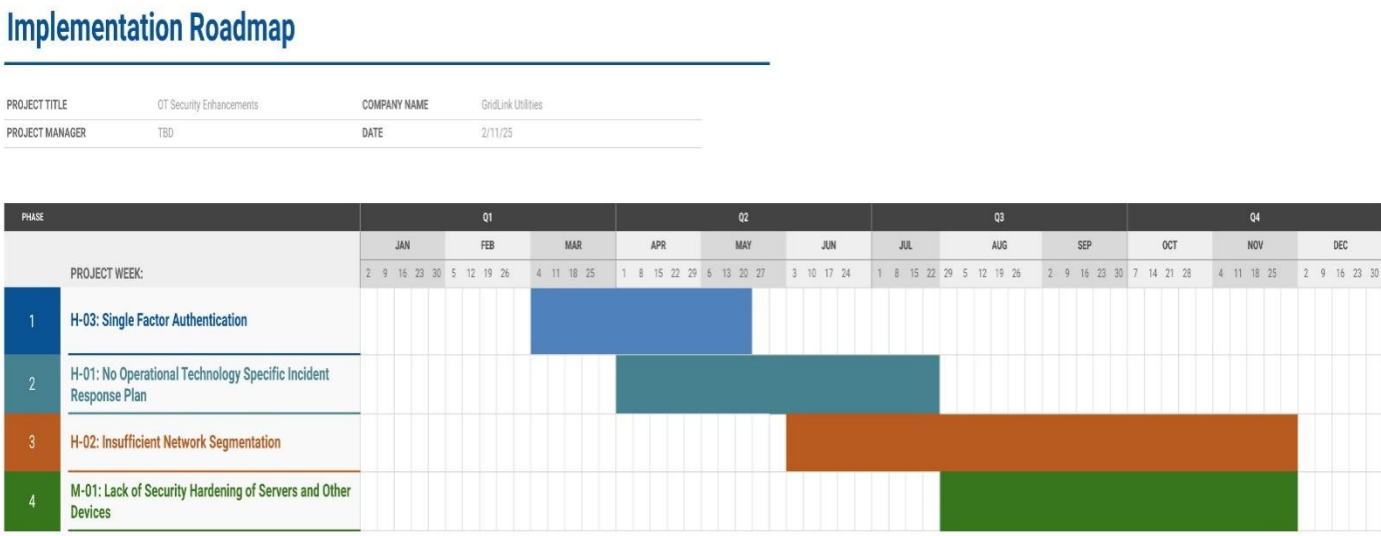
1. **Low**: Minimal impact, easily manageable.
2. **Medium**: Some impact, manageable with some effort.
3. **High**: Significant impact, requires substantial resources to manage.
4. **Critical**: Severe impact, challenging to manage and could cause significant disruption.

Impact				
	Very High	High	Critical	Critical
	High	Medium	High	High
	Medium	Low	Medium	Medium
	Low	Low	Low	Low
		Low	**Medium**	**High**
		Probability		

Prioritization of Findings

Finding (in priority order)	Risk Rating	Duration	Resources
H-03:Single Factor Authentication	**High**	**Low** (less than 3 months)	**Low** (1 resource)
H-01: No Operational Technology Specific Incident Response Plan	**High**	**Medium** (3-6 months)	**Medium** (2 resources)
H-02: Insufficient network segmentation	**High**	**High** (6+ months)	**High** (3+ resources)
M-01: Lack of Security Hardening of Servers and Other Devices	**Medium**	**Medium** (3-6 months)	**Medium** (2 resources)

Implementation Roadmap



Conclusion

Over the past 3 months, the GrindLink Utilities' security team has performed an OT gap assessment. The following areas were in scope for the assessment.

- A current state assessment of GridLink Utilities' OT environment and existing security measures.
- Identification of security gaps in GridLink Utilities' OT environment
- Risk ratings for all gaps identified in this assessment
- Mapping GridLink Utilities' OT network to the Purdue Model.
- Gaps in GridLink Utilities' OT environment were assessed from a risk perspective and prioritized for security posture improvement
- A recommendation plan to address identified gaps and to improve GridLink Utilities' OT security posture has been concluded
- A Recommended implementation roadmap that includes estimated duration and resources required to address the gaps identified has been concluded.

In conclusion, while GridLink has made strides in securing its Operational Technology environment, the gaps contained in this report highlight areas for improvement to mitigate cybersecurity risks effectively. Addressing these gaps will not only comply with industry best practices and regulatory requirements but also enhance the resilience of GridLink Utilities against emerging cybersecurity threats